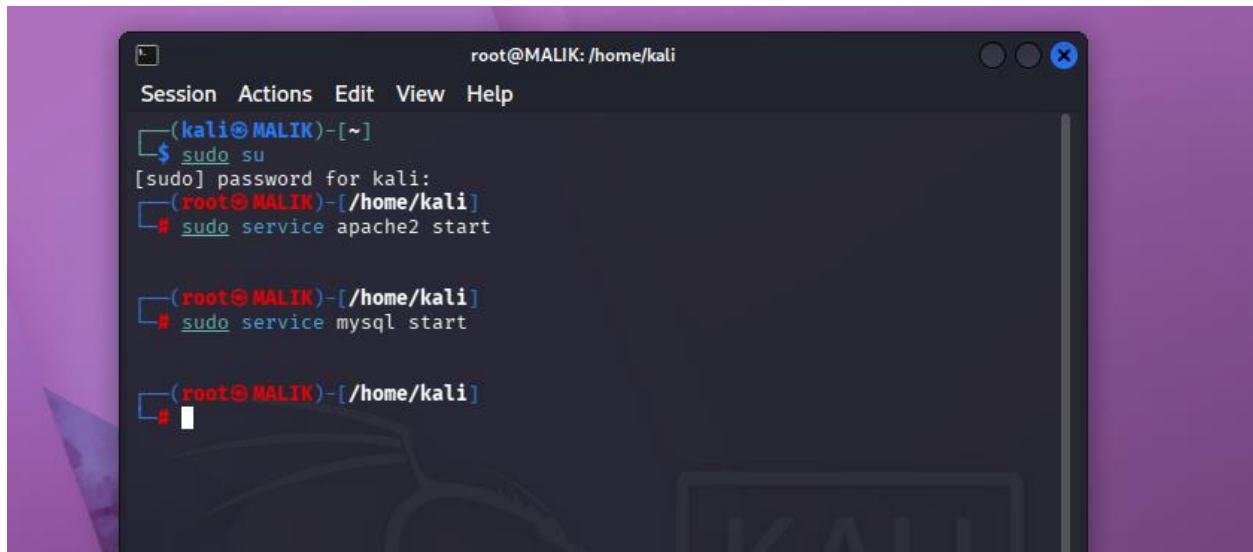


1. Start Apache & MySQL

`sudo service apache2 start`

`sudo service mysql start`

A terminal window titled 'root@MALIK: /home/kali' with a menu bar (Session, Actions, Edit, View, Help). The prompt is '(kali@MALIK)~'. The user enters '\$ sudo su', and the prompt changes to '[sudo] password for kali:'. The user enters '(root@MALIK)~'. The user enters '# sudo service apache2 start'. The prompt changes to '(root@MALIK)~'. The user enters '# sudo service mysql start'. The prompt changes to '(root@MALIK)~'. The user enters '#', and the prompt changes to '(root@MALIK)~'.

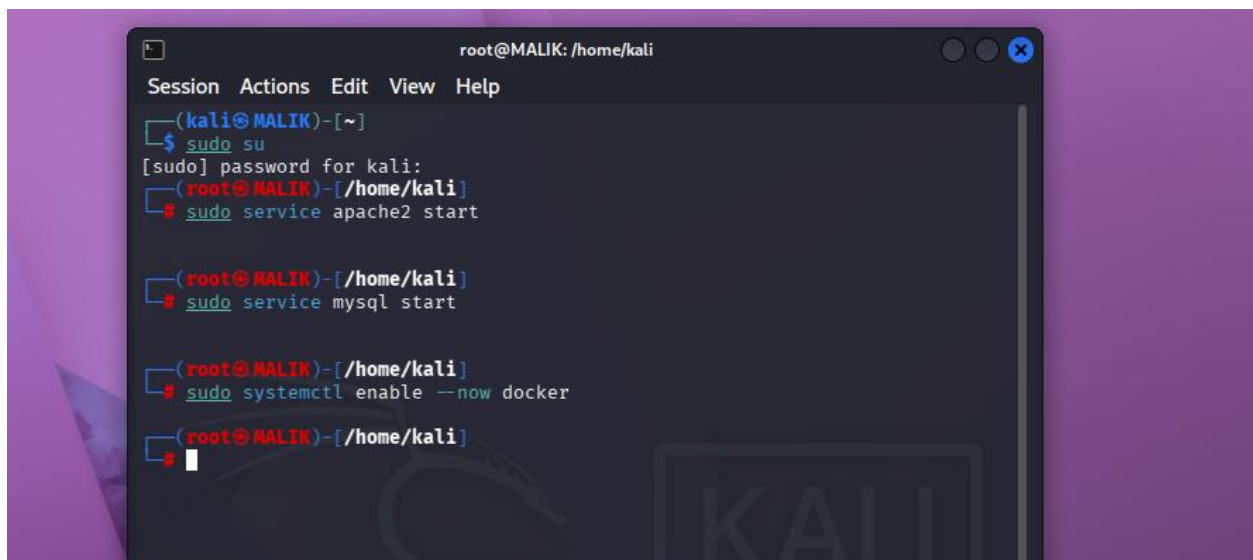
```
root@MALIK: /home/kali
Session Actions Edit View Help
(kali@MALIK)~
$ sudo su
[sudo] password for kali:
(root@MALIK)~
# sudo service apache2 start

(root@MALIK)~
# sudo service mysql start

(root@MALIK)~
#
```

Start Docker Service

`sudo systemctl enable --now docker`

A terminal window titled 'root@MALIK: /home/kali' with a menu bar (Session, Actions, Edit, View, Help). The prompt is '(kali@MALIK)~'. The user enters '\$ sudo su', and the prompt changes to '[sudo] password for kali:'. The user enters '(root@MALIK)~'. The user enters '# sudo service apache2 start'. The prompt changes to '(root@MALIK)~'. The user enters '# sudo service mysql start'. The prompt changes to '(root@MALIK)~'. The user enters '# sudo systemctl enable --now docker'. The prompt changes to '(root@MALIK)~'. The user enters '#', and the prompt changes to '(root@MALIK)~'.

```
root@MALIK: /home/kali
Session Actions Edit View Help
(kali@MALIK)~
$ sudo su
[sudo] password for kali:
(root@MALIK)~
# sudo service apache2 start

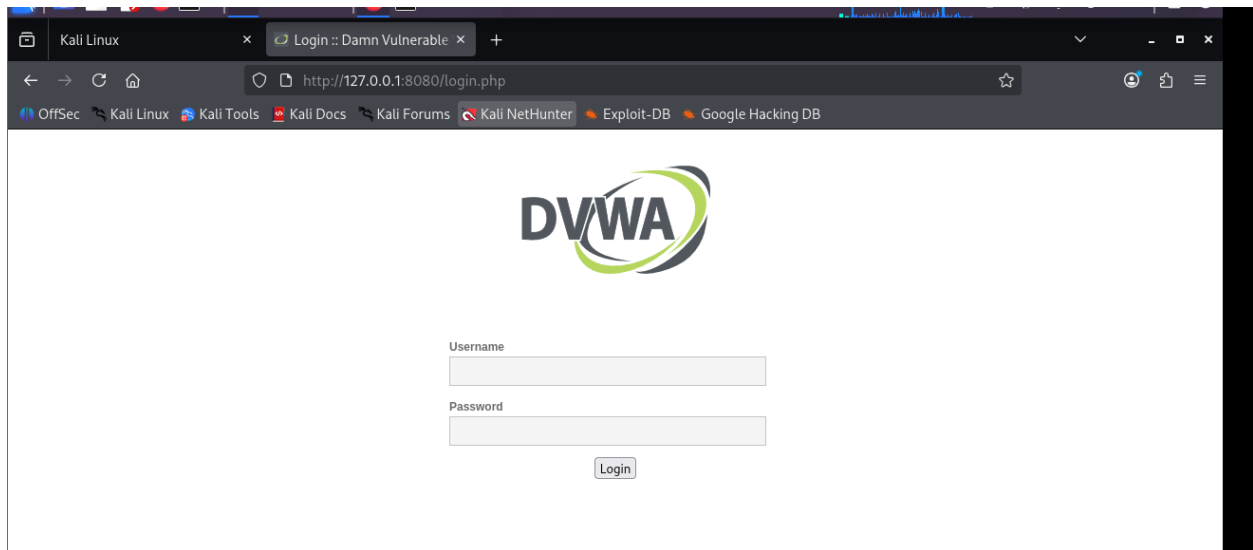
(root@MALIK)~
# sudo service mysql start

(root@MALIK)~
# sudo systemctl enable --now docker

(root@MALIK)~
#
```

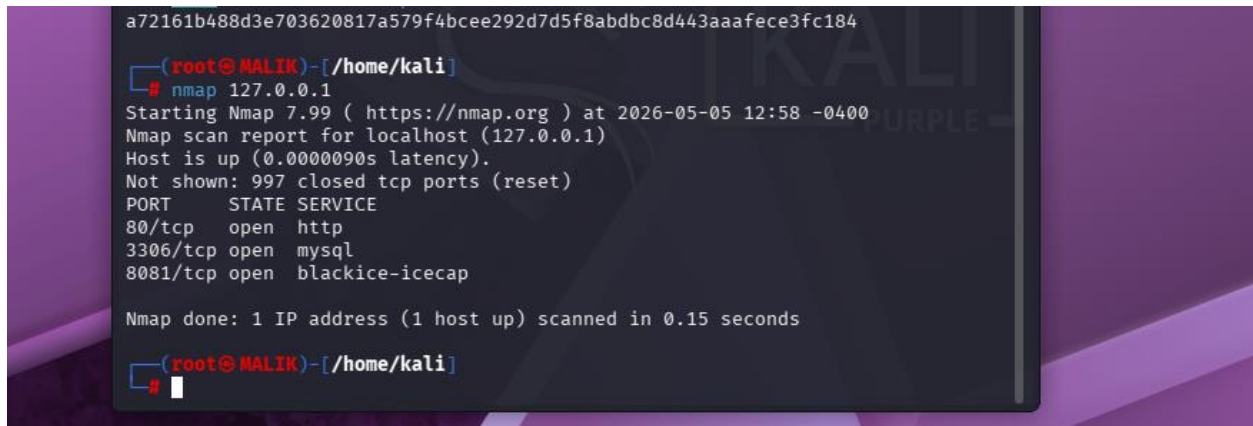
Once Docker is running, you can start DVWA:

<http://127.0.0.1:8080>



Information Gathering & Reconnaissance

NMAP scan for open ports:



Running Services:

- On port 80 http, On port 3306 mysql and on port 8081 blackice-icecap is currently running.

```
a72161b488d3e703620817a579f4bcee292d7d5f8abdbc8d443aaafece3fc184

(root@MALIK)-[/home/kali]
# nmap 127.0.0.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-05 12:58 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000090s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
3306/tcp  open  mysql
8081/tcp  open  blackice-icecap

Nmap done: 1 IP address (1 host up) scanned in 0.15 seconds

(root@MALIK)-[/home/kali]
```

Exploitation (SQL Injection)

By adding SQL queries values we can retrieve data



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

Vulnerability: SQL Injection

User ID:

Submit

ID: 2

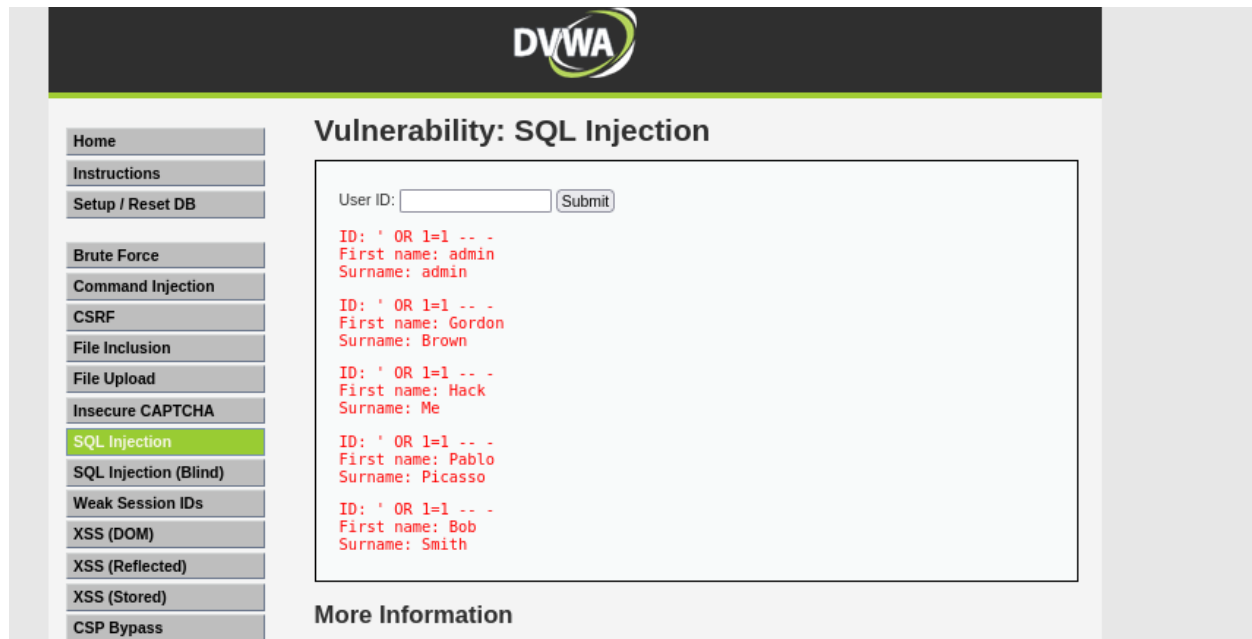
First name: Gordon

Surname: Brown

More Information

- <http://www.securiteam.com/securityreviews/SDP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>

- By using command (' OR 1=1 -- -) show all the user id available in the database.



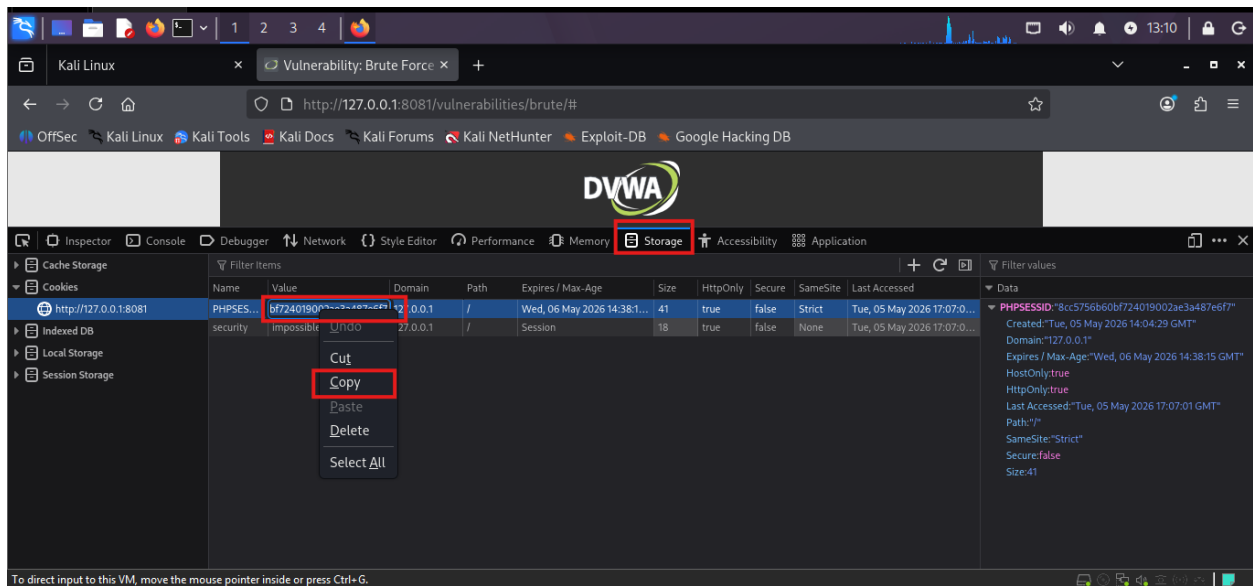
The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The top header features the DVWA logo. On the left, a sidebar contains a list of navigation links: Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection (highlighted in green), SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), and CSP Bypass. The main content area is titled "Vulnerability: SQL Injection". It contains a form with a "User ID:" label, an input field, and a "Submit" button. Below the form, the results of the SQL injection attack are displayed in red text, showing a list of user IDs and their corresponding first and last names. The results are as follows:

ID	First name	Surname
1	admin	admin
2	Gordon	Brown
3	Hack	Me
4	Pablo	Picasso
5	Bob	Smith

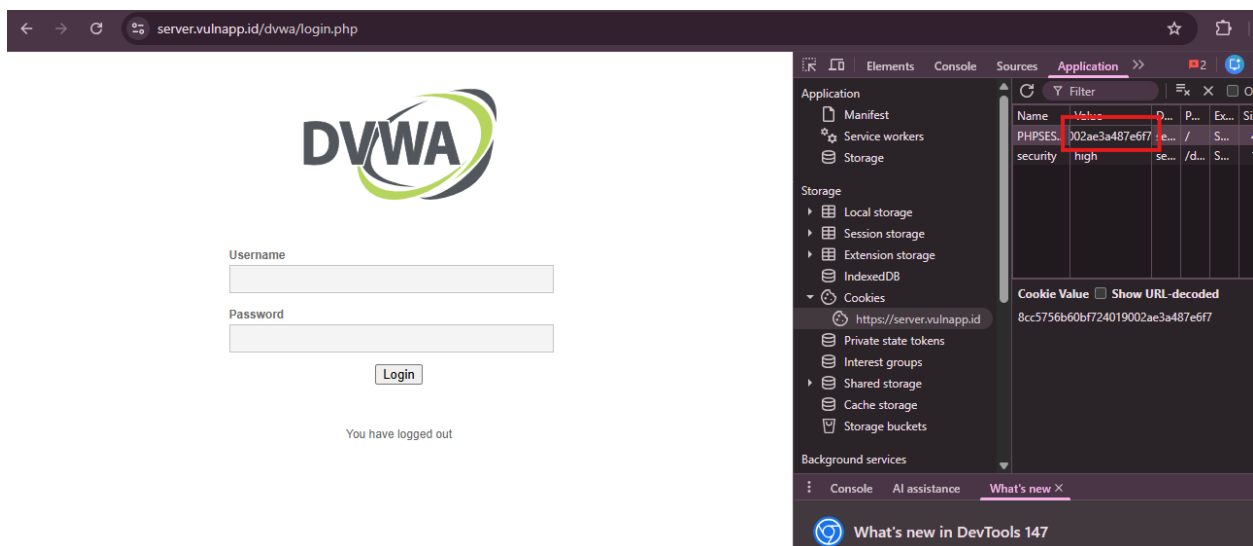
Below the results, there is a section titled "More Information".

Session Hijacking / Cookie Manipulation

- Copying Session ID from Firefox

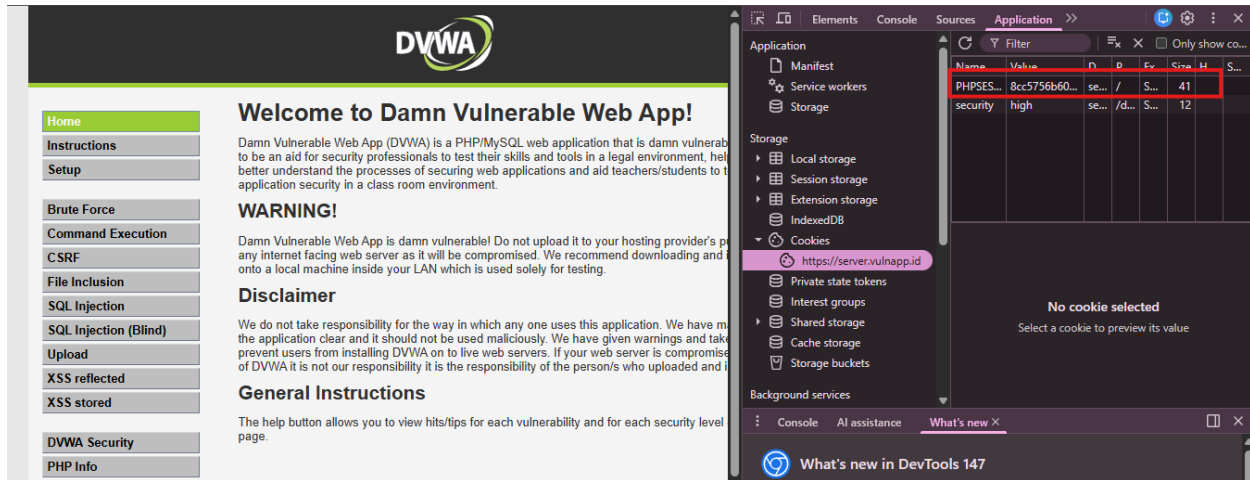


- Pasting Session ID in Chrome



- Login Page Bypassed

After injecting the valid session ID into Chrome the application granted direct access to the authenticated user session



Why the Session is Insecure

The session management in Dvwa is intentionally weak, which makes it vulnerable to session hijacking.

- No session id regeneration.
- Weak session handling.
- Missing secure cookies attributes.
- No session expiration or timed out.